

Phase 1 Curriculum

CERTIFICATION TARGET	SC-300 — Identity and Access Administrator Associate
LEVEL RANGE	Level 1 through Level 15
GATE REQUIREMENT	1,190 XP + SC-300 passing score
TOPIC COUNT	7 topics (5 exam-mapped + 2 continuous tracks)
XP PER TOPIC	200 XP maximum (Quiz 60 · Build Lab 50 · Forensic Lab 50 · Artifact 40)
DOMAIN	Identity — who is this principal, and should they be here?
SOURCE	Microsoft Learn SC-300 study guide, verified April 27, 2026

This document is the Phase 1 study curriculum for the Principal Engineer Track program. It covers every topic, every exam domain, and every XP-earning component for Levels 1–15. All content is derived from Microsoft's official SC-300 study guide and primary regulatory sources. No vendor training material was used.

What is in this document

- 01 Program overview and XP rules
- 02 Level curve — Levels 1 through 15
- 03 Certification gate — SC-300
- 04 Topic 1 — Authentication protocols from the wire up
- 05 Topic 2 — User identities and tenant management
- 06 Topic 3 — Authentication and access management
- 07 Topic 4 — Workload identities
- 08 Topic 5 — Identity governance
- 09 Topic 6A — Compliance as architectural constraint: identity layer
- 10 Topic 7A — Architectural decision-making: identity domain
- 11 How XP is earned — quiz, lab, and artifact rules
- 12 Sources and references

Program Overview and XP Rules

What this program is

The Principal Engineer Track is a structured self-study program designed to take a Senior Systems Administrator to Principal Engineer level in a Microsoft-centric, regulated (biotech/pharma) environment. The program runs across three certification phases, 45 levels, and a maximum of 3,400 XP. Phase 1 covers identity — the foundation every other domain depends on.

The spine

Identity → Device → Data, under audit. The three questions that drive every topic:

- Who is this principal — human or workload — and how do we verify it?
- What device are they on and what is its state?
- What can they do with the data, and can you prove all three to someone hostile?

Why identity comes first

Every other domain — endpoint, data, compliance — depends on having a correct answer to 'who is this, and should they be here.' Conditional Access, device compliance, DLP policies, audit logs — none of them function correctly if the identity layer is wrong. Phase 1 builds that foundation.

How XP is earned

XP is awarded only for demonstrated performance. Reading, watching, or agreeing with an explanation earns nothing. Each topic has four components:

Component	XP	How it is earned
Concept Quiz	60	Score 80%+ on a closed-book quiz on the mechanism, not vocabulary. Below 80% = 0 XP. No partial credit.
Build Lab	50	Predict what will happen before touching the tenant. Build it. Explain where your prediction was wrong and why.
Forensic Lab	50	Read logs or audit output. Diagnose what happened. Explain the mechanism. Lab-based — no passive reading.
Artifact	40	A self-contained document usable by someone other than you. Real organizational context required. A hypothesis is not an artifact.

Rules that make XP mean something

- No credit for near-misses. 79% is a fail.
- Retakes replace, not add. Passing on the third attempt awards 60 XP once.

- Lab XP requires the prediction recorded in advance. Retroactive predictions earn 0.
- Artifact XP requires real organizational context. No hypotheticals.
- No XP for participation, effort, or enthusiasm.
- XP may be deducted if cold recall shows a cleared topic was not retained.
- Certifications are gates only — passing SC-300 does not award XP.

Level Curve — Levels 1 through 15

Phase 1 has 7 topics with a maximum of 200 XP each, giving a ceiling of 1,400 XP. The SC-300 gate sits at 1,190 XP — 85% of the ceiling. You do not need to be perfect, but you cannot coast. The curve steepens as you progress.

Levels	XP per Level	Cumulative to Clear
1 – 3	60 XP	180 XP
4 – 7	100 XP	580 XP
8 – 11	130 XP	1,100 XP
12 – 15	160 XP	1,740 XP available · Gate at 1,190 XP

Certification Gate — SC-300

EXAM	SC-300 — Identity and Access Administrator Associate
STATUS	Current. Updated April 27, 2026. No retirement notice.
SOURCE	learn.microsoft.com/en-us/credentials/certifications/identity-and-access-administrator/
GATE	Level 15 is hard-locked until SC-300 is passed. XP still accrues but level does not advance.
FORMAT	Multiple choice, case studies, drag-and-drop, and scenario-based questions.

SC-300 exam domains

Domain	Name	Weight	Maps to
Domain 1	Implement and manage user identities	20–25%	Topic 2
Domain 2	Implement authentication and access management	25–30%	Topic 3
Domain 3	Plan and implement workload identities	20–25%	Topic 4
Domain 4	Plan and automate identity governance	20–25%	Topic 5

Do not pursue these credentials

Exam	Name	Status
AZ-500	Azure Security Engineer Associate	RETIRED August 31, 2026
SC-400	Information Protection and Compliance Admin	RETIRED — superseded by SC-401
MS-102	M365 Administrator Expert	RETIRING November 30, 2026 — note: MD-102 is NOT retiring

Authentication Protocols from the Wire Up

Foundation — underlies all of Phase 1

This topic is not mapped to a single SC-300 exam domain — it is the foundation every other Phase 1 topic depends on. It covers what is actually in the packet when a principal authenticates, who signs what, who trusts whom, and what each protocol was built to solve. The critical distinction tested throughout SC-300: OAuth 2.0 is an authorization framework, not an authentication protocol.

Kerberos (RFC 4120) — the on-premises answer

- The problem it solves: authenticate a user to a service across a hostile network without the password ever crossing the wire
- Three parties: the client, the service, and the KDC (Key Distribution Centre — every writable domain controller on Windows)
- AS-REQ / AS-REP: client pre-authenticates to the Authentication Service, receives a TGT encrypted with the krbtgt key
- TGS-REQ / TGS-REP: client requests a service ticket for a specific SPN (Service Principal Name)
- AP-REQ: client presents the service ticket — the service decrypts it with its own key, never contacting the KDC at authentication time
- Encryption types — critical for Kerberoasting risk:
 - RC4-HMAC (etype 0x17): low offline cracking cost — unsalted NT hash key
 - AES128-CTS-HMAC-SHA1-96 (etype 0x11): high cost — salted, iterated key derivation
 - AES256-CTS-HMAC-SHA1-96 (etype 0x12): high cost — preferred
 - Detection: Event IDs 4768 (TGT requested) and 4769 (service ticket requested) on KDCs
- RC4 enforcement: Microsoft completed removal of RC4 as a default in July 2026 (CVE-2026-20833) — any remaining RC4 override is an undocumented exception
- msDS-SupportedEncryptionTypes: per-account attribute controlling allowed etypes — value 28 (0x1C) = RC4+AES128+AES256; value 24 (0x18) = AES128+AES256 only

NTLM (MS-NLMP) — the thing Kerberos was meant to replace

- Challenge/response: NEGOTIATE → CHALLENGE (random nonce) → AUTHENTICATE (nonce encrypted with password-derived key)
- Three structural defects: no mutual authentication, no binding to a target (enables relay attacks), pass-the-hash (the hash is the credential)
- Deprecated June 2024 by Microsoft. NTLMv1 removed in Windows 11 24H2 and Server 2025. NTLMv2 still present but deprecated.
- Negotiate/SPNEGO: tries Kerberos first, falls back to NTLM silently — your estate may be running NTLM everywhere Kerberos quietly fails (missing SPN, duplicate SPN, IP address connection)

SAML 2.0 (OASIS Standard, March 2005) — the federation answer

- Problem: a user authenticated in org A needs access to an app in org B — no shared directory, no shared password store
- Three parties: the user's browser, the IdP (Identity Provider), the SP (Service Provider)
- Flow: SP redirects browser to IdP → IdP authenticates user → IdP builds a signed XML assertion → browser POSTs assertion to SP → SP validates signature
- Trust anchor: the IdP's public certificate, exchanged out of band at federation setup — no direct IdP↔SP connection required
- Front-channel (browser-mediated) — this is what made cross-org SSO possible over the public internet
- XML signature wrapping vulnerability: SP fails to canonicalize/validate correctly → attacker moves signed element

OAuth 2.0 (RFC 6749) — the distinction most administrators get wrong

- OAuth 2.0 is an authorization framework, not an authentication protocol
- Answers: may this application act on this resource on this user's behalf, and to what extent — not: who is this user
- Four roles:
 - Resource owner: the user who owns the data
 - Client: the application requesting access
 - Authorization server: issues tokens (Microsoft Entra ID in your estate)
 - Resource server: the API holding the data (e.g. Microsoft Graph)
- Authorization code flow with PKCE: client → AS with code_challenge → user authenticates/consents → AS returns authorization code → client exchanges code back-channel with code_verifier → AS returns access token
- PKCE (Proof Key for Code Exchange): proves the entity redeeming the code is the one that started the flow — prevents code interception on mobile/SPA clients
- Bearer token: possession alone is sufficient — whoever holds it, is it. No proof that the holder is the named principal.
- RFC 9700 (BCP 240, January 2025): current best practice — PKCE for all clients, exact redirect-URI matching, implicit grant out, ROPC grant out, sender-constrained tokens preferred
- Access tokens are opaque to the client — do not parse them. The client must treat them as strings, validate nothing, pass to the resource server.

OpenID Connect Core 1.0 — the authentication layer OAuth lacks

- OIDC is a thin layer on top of OAuth 2.0 — it adds the ID token
- The ID token: a JWT issued to the client describing who authenticated
- Required ID token claims:
 - iss: issuer — must match expected authority exactly
 - sub: subject — stable unique identifier for the user at that issuer
 - aud: audience — MUST equal the client's own client_id
 - exp/iat: expiry and issued-at

- nonce: value client sent in the request; must come back unchanged — this is the replay defence
- The one-sentence version: the ID token is for the client and says who the user is. The access token is for the API and says what may be done. They are not interchangeable.
- Confused deputy problem (CWE-441): validating and accepting tokens meant for another resource — a real vulnerability, not a theoretical one

The two eras and why Conditional Access exists

- Kerberos: token cryptographically bound to one service; service decrypts with its own key; offline cracking of service account key is the failure mode
- OAuth/OIDC: aud claim is a string checked by the recipient; bearer token; possession is sufficient; token theft and replay is the failure mode
- Conditional Access is a pre-issuance gate. A stolen bearer token is a post-issuance fact. This is the seam Topic 3 lives in.

A CA policy defeated by a stolen refresh token is a policy that does not exist. The bearer-token model at the protocol level is what lets you identify the gap between 'portal' and 'actually enforced at authentication time.'

User Identities and Tenant Management

SC-300 Domain 1: Implement and manage user identities · 20–25% of exam

This domain covers the full lifecycle of identities in a Microsoft Entra tenant — from tenant configuration and role management through user and group creation, hybrid identity, and external collaboration. It is the broadest domain on SC-300 and the one most directly tied to daily administration work.

Configure and manage a Microsoft Entra tenant

- Built-in and custom Entra roles: understand least-privilege assignment, role scope, and the difference between directory roles and Azure RBAC roles
- Administrative units: containers that scope administrative permissions to a subset of users, groups, or devices — when to use and how to configure
- Evaluating effective permissions: how role assignments combine, inheritance, and exclusions
- Domain settings: custom domain verification, primary domain designation
- Tenant-level settings: user and guest permissions, collaboration settings, device settings, group creation policies

Create, configure, and manage Microsoft Entra identities

- Users: creation methods (portal, PowerShell, bulk import via CSV), account properties, authentication contact methods
- Groups: security groups vs Microsoft 365 groups, assigned vs dynamic membership, dynamic membership rules, nested groups
- Custom security attributes: extending the directory schema for organization-specific classification
- Bulk operations: PowerShell (New-MgUser, Set-MgUser, Get-MgUser) and Entra admin center bulk operations
- Device identities: Entra join, Entra registration, hybrid Entra join — what each means and what access it grants
- License assignment: direct vs group-based licensing, license conflict resolution, service plan management

External users and tenants

- External collaboration settings: who can invite guests, what guests can access, cross-tenant access policies
- B2B invitations: individual invitation flow, bulk invitation via CSV, invitation redemption experience
- Managing external user accounts: access review lifecycle, automatic cleanup, blocking sign-ins
- Cross-tenant access settings: inbound and outbound trust settings, automatic redemption
- Cross-tenant synchronization: syncing identities from a partner tenant into your directory
- External identity providers: SAML/WS-Fed federation for organizations without Entra ID

Hybrid identity

- Entra Connect Sync: synchronizing on-premises Active Directory to Entra ID — filtering, attribute mapping, sync rules
- Entra Cloud Sync: lightweight agent-based sync — when to choose over Connect Sync
- Password hash synchronization (PHS): how password hashes are synchronized and what this enables (seamless SSO, leaked credential detection)
- Pass-through authentication (PTA): authentication forwarded to on-premises AD — no password hash in cloud
- Seamless SSO: automatic sign-in for domain-joined devices without additional prompts
- Migration from AD FS: staged rollout, cutover considerations
- Entra Connect Health: monitoring sync errors, agent health, sign-in activity

Identity lifecycle gaps — orphaned accounts, over-privileged guests, unsynced accounts — are among the most common audit findings in regulated environments. Owning this data is the first step in the conversation.

Authentication and Access Management

SC-300 Domain 2: Implement authentication and access management · 25–30% of exam

The largest domain on SC-300. Covers authentication methods, MFA, SSPR, Conditional Access policy design and evaluation, Identity Protection risk signals, and Global Secure Access. This domain is where the protocols from Topic 1 become operational controls.

Authentication methods

- Certificate-based authentication (CBA): X.509 certificate as a credential — stronger than password, no phishing vector
- Temporary Access Pass (TAP): time-limited passcode for onboarding or recovery — not a persistent credential
- FIDO2 passkeys: hardware-bound or device-bound passkeys — phishing-resistant, no shared secret
- Microsoft Authenticator: push notifications, number matching, additional context display
- Tenant-wide MFA settings: security defaults vs Conditional Access policies — understanding which controls which
- SSPR (Self-Service Password Reset): authentication methods allowed, registration policy, writeback to on-premises AD
- Windows Hello for Business: device-bound credential using TPM — certificate vs key trust deployment models
- Password protection: banned password list, on-premises proxy agent for AD
- Entra Kerberos for hybrid: issuing Kerberos tickets from Entra ID for on-premises resources without requiring domain join

Conditional Access

- Policy evaluation: all matching policies are evaluated; the most restrictive grant control wins across all matching policies
- Assignments: users/groups, cloud apps or actions, conditions (sign-in risk, user risk, device platform, location, client app, device state, authentication strength)
- Grant controls: require MFA, require compliant device, require hybrid Entra joined device, require approved app, require app protection policy, terms of use
- Session controls: sign-in frequency, persistent browser session, application-enforced restrictions, Defender for Cloud Apps controls
- What CA structurally cannot see: actions taken after token issuance — once a token is issued, CA has no visibility until the next authentication
- Continuous Access Evaluation (CAE): real-time enforcement for specific critical events (user disabled, password changed, risky sign-in) without waiting for token expiry
- Authentication context: step-up authentication for specific actions within an application

- Protected actions: requiring re-authentication for high-privilege directory actions
- Testing: What If tool, sign-in logs, audit logs — how to validate policy behavior without breaking production

Identity Protection

- User risk: cumulative signal suggesting an account is compromised — leaked credentials, impossible travel, anomalous token
- Sign-in risk: signal that the specific sign-in attempt may not be by the account owner
- Risky workload identities: service principals and managed identities with anomalous behavior signals
- CA integration: require MFA or block based on risk level — how to configure risk-based policies
- MFA registration campaign: requiring users to register authentication methods before risk becomes a problem
- Monitoring and remediation: investigating risky users, confirming compromise vs dismissing, admin reset vs self-remediation

Global Secure Access

- Private Access: Zero Trust Network Access (ZTNA) replacing VPN for on-premises application access
- Internet Access: Secure Web Gateway (SWG) for internet-bound traffic — web content filtering, FQDN rules
- Internet Access for Microsoft 365: optimized path for M365 traffic — bypass and direct routing
- Client deployment: Global Secure Access client installation and configuration on Windows devices

A CA policy that looks correct in the portal but is defeated by a stolen refresh token can exist. The architect-level skill is knowing the difference between 'configured' and 'able to demonstrate that difference to an auditor.'

Note: Manager sign-off required before running live token-replay lab in the dev tenant. Topic 3 lab may pivot to sign-in log forensics and design review if not obtained.

Workload Identities

SC-300 Domain 3: Plan and implement workload identities · 20–25% of exam

Workload identities are non-human identities: service principals, app registrations, and managed identities. This domain covers how applications authenticate to Microsoft cloud services, how permissions are granted and consented to, and how to govern application access at scale. The most misunderstood and under-governed area in most tenants.

Identity types for applications and Azure workloads

- Selecting the right identity type:
 - Managed identity: system-assigned or user-assigned; no credential management; Azure resources only; preferred for any workload running in Azure
 - Service principal: a directory object representing an application — requires credential management (secret or certificate)
 - User account: should not be used for applications — no audit trail differentiation, subject to user lifecycle
 - Managed service account: on-premises Active Directory concept — not the same as a managed identity
- Creating managed identities: system-assigned (lifecycle tied to the resource) vs user-assigned (independent lifecycle, can be shared)
- Assigning managed identities to Azure resources: VMs, App Service, Logic Apps, Azure Functions, AKS
- Using managed identity to access other resources: role assignment on the target resource, token acquisition via IMDS endpoint

App registrations

- What an app registration is: a directory object defining the application's identity, authentication configuration, and API permissions
- App registration vs enterprise application (service principal): the app registration is the definition; the enterprise application (service principal) is the instance in a tenant — one app registration can have service principals in multiple tenants
- Authentication configuration: redirect URIs, supported account types, implicit grant settings, certificates and secrets
- API permissions: delegated permissions (acting as the signed-in user) vs application permissions (acting as itself with no user present)
- Consent: user consent (delegated, low-privilege), admin consent (required for application permissions and high-privilege delegated), tenant-wide admin consent
- App roles: custom roles defined in the app manifest — assigned to users, groups, or other service principals
- Secrets vs certificates: certificates are preferred — they have a public/private key pair; secrets are shared symmetric strings that cannot be rotated without a window

Enterprise applications

- Application-level and tenant-level settings: user assignment required, visible to users, sign-in logs enabled
- Assigning Entra roles for app management: Application Administrator, Cloud Application Administrator, Application Developer
- Application Proxy: publishing on-premises web applications through Entra ID — connector groups, pre-authentication, single sign-on configuration
- SaaS app integration: gallery apps vs custom SAML/OIDC apps, provisioning configuration
- User, group, and app role assignments: who can access the application and with what role
- Admin consent workflow: delegating consent decisions without granting permanent admin rights

Defender for Cloud Apps

- Cloud discovery: analyzing traffic logs to identify sanctioned and unsanctioned applications
- Connected apps: API connectors to major SaaS applications for visibility and governance
- Application-enforced restrictions: enforcing session controls for specific SharePoint/Exchange conditions
- CA app control: routing sessions through Defender for Cloud Apps for real-time inspection and control
- OAuth app policies: detecting and governing OAuth apps granted access by users in your tenant

Over-permissioned service principals are the quietest catastrophe in a Microsoft environment. No sign-in risk signal, often no expiry, frequently Directory.ReadWrite permissions. This was a major issue during the Microsoft 365 debugging in 2023. Auditors care about this intensely. Most administrators

Identity Governance

SC-300 Domain 4: Plan and automate identity governance · 20–25% of exam

Identity governance is the systematic management of who has access to what, for how long, and under what review cycle. This domain covers entitlement management (structured access request and approval), access reviews, Privileged Identity Management (time-bound elevated access), and monitoring through logs and KQL queries.

Entitlement management

- Catalogs: containers for resources (applications, SharePoint sites, groups) and access packages
- Access packages: bundles of resources with defined policies for who can request access, approval workflow, and access duration
- Access requests: self-service request flow, approval stages, justification requirements
- Terms of use: requiring policy acceptance as a condition of access
- External user lifecycle: auto-assignment and auto-removal for guest accounts through access packages, connected organizations
- Connected organizations: trusted external tenants or domains whose users can request access

Access reviews

- Planning: who reviews, how often, what scope (users, groups, applications, privileged roles)
- Creating and configuring: reviewer type (managers, resource owners, specific reviewers, self-review), recurrence, duration
- Monitoring: review progress, send reminders, view decisions
- Auto-apply results: automatically remove access when reviewers say no or when no response within the review period
- Manual response: what happens to no-response decisions — deny or approve

Privileged Identity Management (PIM)

- PIM for Entra roles: converting permanent role assignments to eligible assignments with time-bound activation
- Activation settings: MFA requirement on activation, justification required, approval required, maximum activation duration
- PIM for Azure resources: same model for Azure RBAC roles — subscription, resource group, or resource scope
- PIM for Groups: eligible membership in groups used for access to applications or systems
- Request and approval: activation request flow, approver notification, approval/denial with justification
- Audit history and reports: who activated what role, when, with what justification — the primary evidence for access reviews under GxP and SOX

- Break-glass accounts: emergency access accounts excluded from PIM and MFA — why they must exist and how to monitor them

Monitoring and KQL

- Sign-in logs: interactive and non-interactive sign-ins, service principal sign-ins, managed identity sign-ins
- Audit logs: directory changes — role assignments, group membership changes, application consent grants
- Provisioning logs: automatic provisioning activity to applications and HR-driven provisioning
- Diagnostic settings: routing logs to Log Analytics workspace, storage account, or Event Hub for retention beyond the default 30 days
- KQL queries in Log Analytics: filtering sign-in logs for specific conditions, joining audit and sign-in data, building workbooks
- Identity Secure Score: point-in-time measurement of identity configuration against Microsoft's recommended controls

PIM audit history and access review records are the primary evidence a G
'how do you know only authorized people have access to this system.' Thi
identity configuration into audit-ready evidence.

SECTION 6A

TOPIC
6A

Compliance as Architectural Constraint: Identity Layer

Continuous track — Phase 1 installment · Not a standalone exam domain

Regulatory scope is determined per record and per system, not per company. This topic applies that principle to identity infrastructure. It is not about compliance as a checklist — it is about understanding which regulatory regimes actually bind which identity systems, and why.

Core principle

- The intuitive model — 'we are a biotech, therefore every system is regulated' — is wrong in both directions
- Over-scoping is the expensive failure: it burns validation budget on systems that needed none, while burying systems that genuinely matter in noise
- Being the person who can defend a narrower, correct scope is worth more than being the person who validates everything

GxP / 21 CFR Part 11 — triggered by predicate rules

- Part 11 applies only to records required by a predicate rule (GMP, GCP, GLP) and kept electronically
- 'Predicate rule' is the load-bearing term: Part 11 does not create record requirements — it governs how you may keep records that some other rule already demands
- FDA interprets Part 11 narrowly — stated explicitly in their scope and application guidance
- Your Intune tenant is not GxP because it is Intune. It may be in scope if it is the control enforcing access to a GxP system.
- The boundary is evidentiary, not technical: FDA may consider your business practices in determining scope regardless of what your SOP claims

SOX — public companies only, in-scope systems only

- SOX applies to publicly traded companies. Pre-IPO: may build toward it, but not yet bound.
- IT General Controls (ITGC): access provisioning/deprovisioning, segregation of duties, change management, periodic access recertification
- PIM in Entra ID directly supports SOX ITGC: time-bound access, approval workflow, audit history
- Access reviews directly support SOX ITGC: periodic recertification evidence

HIPAA — most biotechs are not covered entities

- Three covered entity categories: health care providers (when transmitting electronically in standard transactions), health plans, health care clearinghouses
- Pharmaceutical and biotech companies appear nowhere on that list
- Clinical trial data is generally governed by ICH-GCP, not HIPAA — unless you hold a BAA with a covered entity

- Question to take to Legal: do we hold a BAA with anyone? If not, on what basis does HIPAA bind us?

Phase 1 artifact: regulatory scope map

- One row per identity system you administer
 - Columns: system, predicate rule / GxP scope, SOX ITGC scope, HIPAA (BAA exists?), ISO/SOC 2 SoA, evidence I can produce today, determination owner
 - You draft the map; QA, Regulatory, and Legal correct it — being wrong on the first draft is expected
 - Blank cells are findings, not omissions — a system nobody can classify is itself the finding
 - Row one: the dev tenant itself
-

SECTION 7A

TOPIC 7A

Architectural Decision-Making: Identity Domain

Continuous track — runs from session one · Not a standalone exam domain

This topic is about writing. Not documenting what you built — writing that changes decisions. The output is one decision record or gap analysis document scoped to identity architecture. It must be self-contained and usable by someone other than you. It is drafted as a candidate founding document for the 2027 infrastructure team.

Why this runs from session one

- When an organization forms a new infrastructure team, there is a narrow window in which standards get written
- Whoever writes those standards becomes the de facto technical authority — regardless of title
- Every topic's artifact is simultaneously a study exercise and a founding document candidate
- 2027 is the formation year. 2029 is when the Principal rung appears. The decisive work happens in 2027.

What a decision record contains

- Context: the situation that required a decision, stated precisely enough that someone unfamiliar can understand the constraint
- Decision: what was chosen, stated without hedging
- Rationale: why this option over the alternatives — including what was rejected and why
- Consequences: what becomes easier, what becomes harder, what is now constrained
- Status: proposed, accepted, superseded, deprecated

Identity domain artifact options

- Authentication path inventory: one row per authentication path in the estate — protocol in use, Kerberos etype observed, msDS-SupportedEncryptionTypes override, SAML cert expiry, evidence producible today
- Conditional Access architecture decision record: why certain policies are structured as they are, what alternatives were rejected, what the evaluation order implies
- Workload identity inventory: all service principals and managed identities, their permissions, expiry status, last activity, documented business owner
- PIM configuration decision record: which roles are PIM-enabled, activation settings chosen, approval chain, rationale for break-glass account configuration

Standards for artifact XP

- Real organizational context required — a hypothetical diagram earns 0 XP
 - Self-contained: a reader who was not in the conversation that produced it must be able to use it
 - Defensible: if an auditor asked 'how do you know this is accurate,' the answer must exist in the document
-

How XP is Earned — Detailed Rules

Concept Quiz — 60 XP

Closed-book. One question at a time. No hints before an answer is attempted. The questions test mechanism and understanding, not vocabulary recognition. A question like 'what does OAuth 2.0 do' is vocabulary. A question like 'explain why an access token should be treated as opaque by the client even when it appears to be a decodable JWT' is mechanism.

- Score 80% or above to earn 60 XP. Below 80% = 0 XP.
- No partial credit. 79% is a fail.
- Retakes unlimited and unpenalized. The score is the score.
- Retakes replace, not add. Third-attempt pass = 60 XP once.

Build Lab — 50 XP

The lab award is shaped around the predict → build → explain sequence deliberately. Building something that works proves you can follow steps. Predicting what will happen and then being wrong in a way you can explain proves you have a mental model — and repairing a broken model is where learning actually happens.

- Write your prediction before touching the tenant. Save it. Do not edit after starting.
- Build the thing. Record what actually happened.
- Explain every prediction that was wrong. 'I guessed' is not an explanation.
- A wrong prediction you can explain is a full pass and costs nothing.
- Skipping the prediction step earns 0 XP regardless of how well the build went.

Forensic Lab — 50 XP

Read logs or audit output that you did not generate yourself. Diagnose what happened. Explain the mechanism that produced the observed evidence. This is the skill an auditor asks for: not 'did you configure this' but 'can you explain what this log entry means and what sequence of events produced it.'

- Lab-based: requires active analysis, not passive reading.
- Data sources: Entra sign-in logs, audit logs, KDC event logs (4768/4769), PIM audit history.
- Output: written explanation of what the logs show, what it means, and what you would do next.

Artifact — 40 XP

A document that is usable by someone other than you. Not notes. Not a study summary. A document another person could act on. It must have real organizational context — the actual systems you administer, the actual controls in place, the actual gaps.

- Real organizational context required. A hypothetical diagram earns 0 XP.
- Self-contained: a reader not present in the conversation that produced it must be able to use it.
- Drafted as a candidate founding document for the 2027 infrastructure team — same work, two payoffs.

Sources and References

Primary sources only. No training vendors. No blog posts unless no primary source exists.

Source	Document	URL
RFC 4120	The Kerberos Network Authentication Service (V5)	https://www.rfc-editor.org/rfc/rfc4120
RFC 6749	The OAuth 2.0 Authorization Framework	https://www.rfc-editor.org/rfc/rfc6749
RFC 9700	Best Current Practice for OAuth 2.0 Security (BCP 240, January 2025)	https://datatracker.ietf.org/doc/rfc9700/
OIDC Core	OpenID Connect Core 1.0 incorporating errata set 2	https://openid.net/specs/openid-connect-core-1_0.html
OASIS	Security Assertion Markup Language (SAML) v2.0	https://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf
MS Learn	SC-300 study guide — verified April 27, 2026	https://learn.microsoft.com/en-us/credentials/certifications/resources/study-guides/sc-300
MS Learn	Deprecated features in the Windows client (NTLM)	https://learn.microsoft.com/en-us/windows/whats-new/deprecated-features
MS Learn	Detect and remediate RC4 usage in Kerberos	https://learn.microsoft.com/en-us/windows-server/security/kerberos/detect-remediate-rc4-kerberos
MS Support	Manage Kerberos KDC usage of RC4 (CVE-2026-20833)	https://support.microsoft.com/en-us/topic/how-to-manage-kerberos-kdc-usage-of-rc4-for-service-account-ticket-issuance-changes-related-to-cve-2026-20833-1ebcda33-720a-4da8-93c1-b0496e1910dc
MS Learn	Access tokens in the Microsoft identity platform	https://learn.microsoft.com/en-us/entra/identity-platform/access-tokens
FDA	Part 11, Electronic Records; Electronic Signatures: Scope and Application	https://www.fda.gov/regulatory-information/search-fda-guidance-documents/part-11-electronic-records-electronic-signatures-scope-and-application
HHS	Covered Entities and Business Associates	https://www.hhs.gov/hipaa/for-professionals/covered-entities/index.html
StaffEng	Introduction — Staff Engineer archetypes	https://staffeng.com/guides/overview-overview/

This curriculum was built from Microsoft Learn primary sources only. All exam domain weights and topic coverage verified against the SC-300 study guide as of April 27, 2026. Regulatory content (GxP, HIPAA) verified against FDA and HHS primary sources. No training vendor material was used in the construction of this document.